

企业安全团队的生存之道

王哲

宜人贷信息安全兼运维总监

议题内容简介

企业安全团队的建设过程中，不同阶段面临着不同优先级的
问题，也有着不同的目标和追求。从安全的底线到更高的标
准，如何有的放矢地开展安全工作、促进企业的发展、为业
务保驾护航，如何更好地展现安全工作的价值、量化安全工
作的产出，以及安全工作的资源分配等等，安全团队的生存
之道充满了挑战与智慧.....

介绍

宜人贷 (NYSE: YRD) 是中国在线金融服务平台, 由宜信公司2012年推出。

宜人贷通过互联网、大数据等科技手段, 为中国城市白领人群提供信用借款咨询服务, 以及为投资者提供理财咨询服务。



2015年12月18日宜人贷在美国纽交所成功上市, 成为中国互联网金融海外上市第一股。

2016

- 创新: YISRC, 行业首个安全漏洞、情报收集平台
- 合规: 迎合监管, 行业首批等保三级备案
- 品牌: 安全品牌运营, 行业独树一帜
- 领先: 安全技术、安全管理体系, 行业标杆



230位白帽子注册



150个安全漏洞提交



30万元漏洞奖励发放



90.1高分通过等保三级备案



10篇技术干货文章发表



内部超过15场安全技术培训、安全意识推广



10次外部安全会议参与



两套实时安全监控系统自研



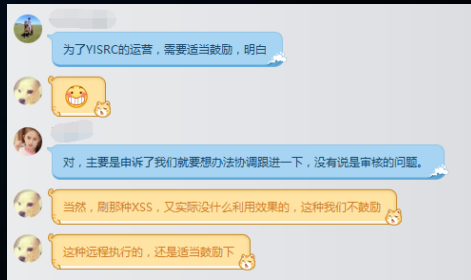
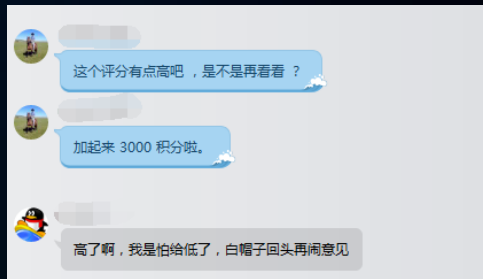
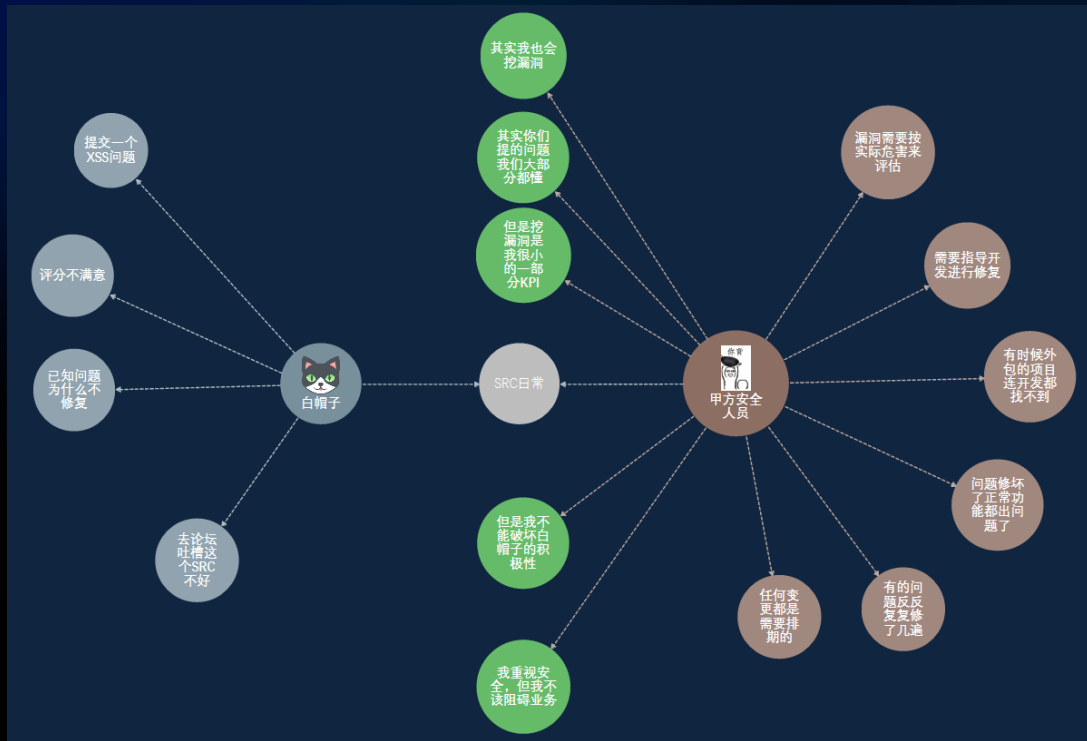
SDLC应用安全全流程覆盖



Topics

- 甲方安全人员的日常
- 安全工作中的用户体验
- 安全工作的数据化运营
- 安全能力产品化的探索
- 以数据安全风险为核心

甲方安全人员的日常



甲方安全人员的日常



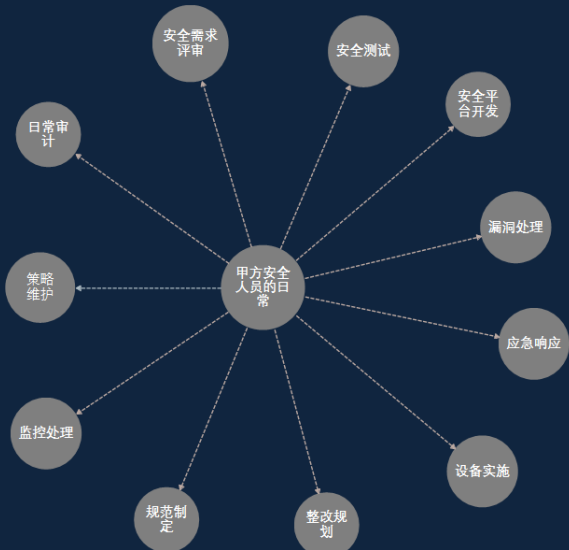
安全就会天天没事找事

又往电脑装监控

又误拦截了

安全阻碍了业务发展

别出去吹牛X了，都被日站了



分类	任务描述	具体任务
业务安全	安全数据服务	数据服务目前已积累虚假手机号、阿里小号 204万条 (实时存证号)
	风控引擎	底层技术框架重写 (替换spring-boot (进行中) 数据表结构的定义 (进行中) 完成了 iRule、TerminateRule 和名单规则, 并测试完成 (已完成) 待压测 (进行中)
	安全中心	提高用户安全性, 安全团队主导的产品, 目前还在需求阶段, (进行中)
	业务安全平台设计	业务安全平台流程制定 (进行中)
安全开发	NETSKY监控系统	需求报警发送相关逻辑 (已完成) 数据排查需求bug修复 (已完成) 编辑策略页面可设置多个手机号以及邮箱 (已完成)
安全技术	SDLC-安全测试	渠道投递短信验证码安全测试 (已完成) 主站数据注册可正常登录处理 (已完成) 数据工程师代码库安全事件处理 (已完成) github监控文件处理 (已完成) 互入员工站安全问题修复测试 (已完成)
	安全平台开发	安全申请-安全测试以及需求审计申请, 产品原型设计 (进行中)
	APP安全加固项目	推进借款app加固的上线 (进行中) app渠道监控系统定期查看 (进行中)
	数据库审计项目实施	数据库安全告警场景及需求配置 (进行中)
	安全审计	数据工程师周六脚本修改失败导致hadoop账户被删除。
安全管理和运营		1. 2密码LDAP绕过认证漏洞测试、修复 (已完成)
	基础安全架构&数据安全	补充 无线AP的验证测试 (进行中) 排查数据工维调研报告 (已完成) 数据数据使用安全策略、策略部署 (已完成) DLP平台的维护和分析, 发现潜在的风险 (进行中)
	安全合规&安全管理	1、数据工维调研报告 (已完成) 2、出借和借款业务数据调研, 访谈借款3位、出借1位同事 (进行中) 3、编写《设备账号及权限管理指引》, 收集多个系统现有安全、运维角色及权限进行整理 (进行中) 4、FM1218安全小课堂 (已完成) 5、FM1218二期安全专项需求对接 (已完成)
	YISRC	YISRC日常运营 YISRC日常处理, 公众号维护, 漏洞跟进审核及订单处理, 申诉处理等 各安全媒体及src相关合作事宜跟进 (进行中) 各安全媒体企业号申请完成 本月安全技术文章一篇, 推广至微信及各媒体 YISRC二期需求 需求原型图设计 (进行中) 安全公益项目 计划调整 (进行中)

安全工作中的用户体验

漏洞修复通告

做法1：别人一脸懵X

做法2：大家合作愉快

一封描述不清晰的邮件，把责任全部抛给其他团队

主题：【高危漏洞预警通告--请于18点前完成修复】XX组件存在远程命令执行漏洞

等线 10.5

安全部收到安全情报，XX组件存在高危安全漏洞，可远程执行服务器系统命令，可直接导致服务器被入侵。为了保证系统安全，请升级对应版本的安全补丁。请各部门负责人务必高度关注，并转发通知至所在部门和产品线高优处理，于18点前完成修复。

漏洞说明

复现说明

确定明确受影响主机或服务

CMDB资产筛选

Ansible批量确认

IP访问限制

修复方式

WAF加对应特征

升级补丁

评估修复方案

修复周期

可能存在的修复风险

漏洞修复过程中的支持

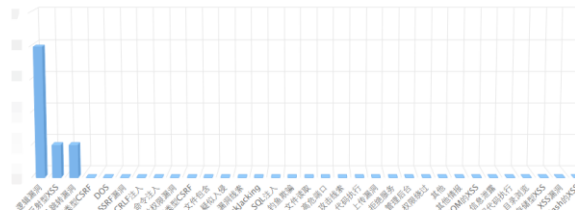
组织复测

确认漏洞修复工作结果

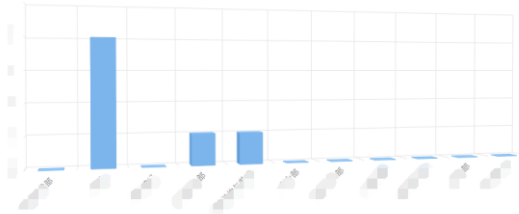
安全工作的数据化运营



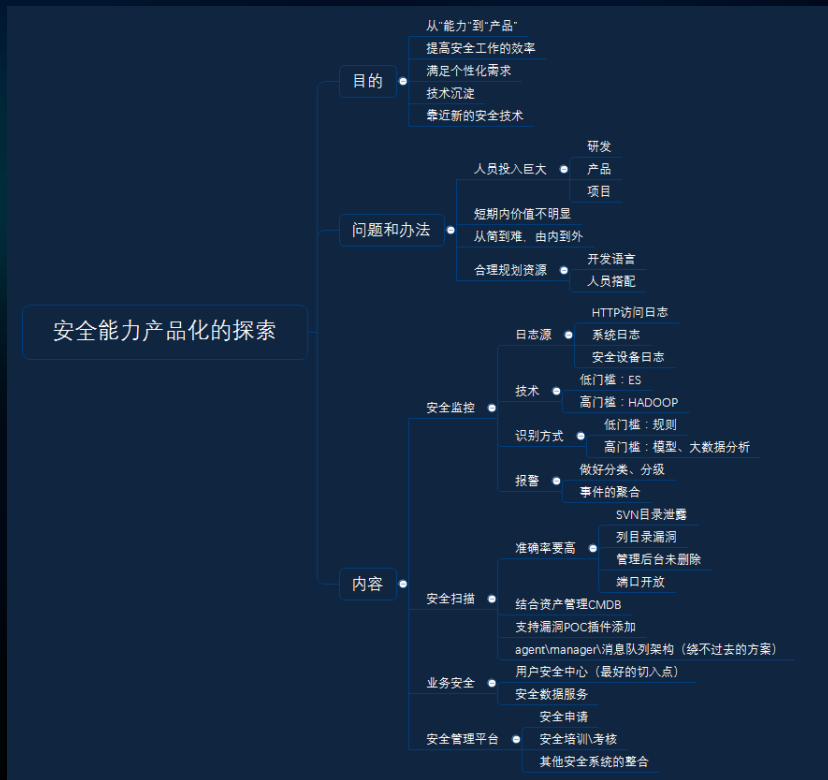
漏洞类型统计



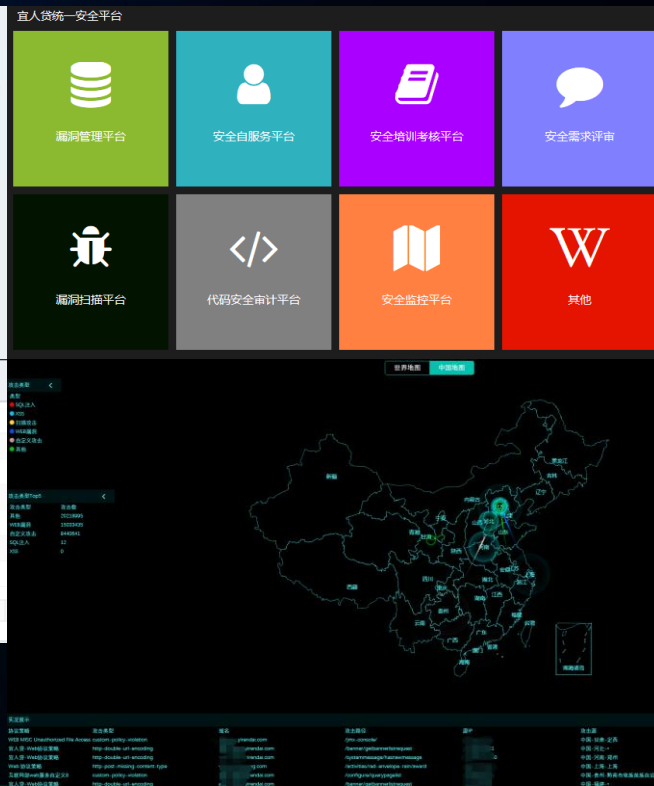
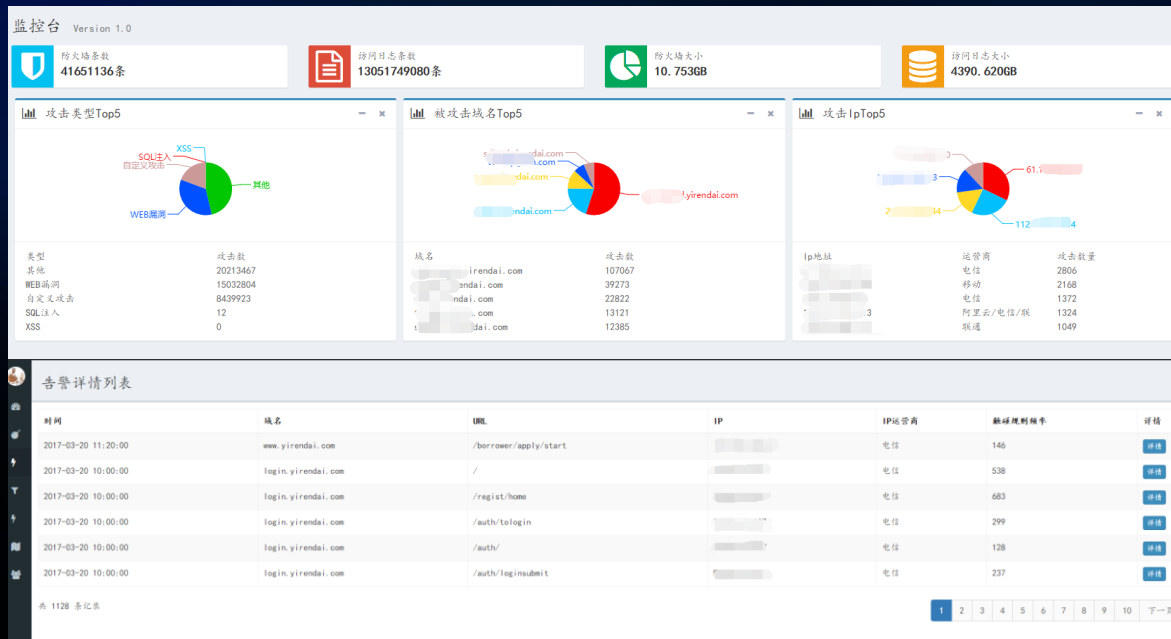
部门漏洞总数统计



安全能力产品化的探索



安全能力产品化的探索



安全能力产品化的探索

功能	数据类型	数据标签	对应数据ID	设置时间
数据服务	手机号	手工录入		
		羊毛党		
		手机验证码平台		
		阿里小号		
		老赖用户		
		贷款中介		
	手机号归属地	第三方风险数据		
		数据部黑名单		
		风控发名单		
		盗刷		
		欺诈用户		
		出清高危区域		
设备ID	IP地址	手工录入		
		代理IP		
		攻击IP		
		漏洞IP		
		欺诈用户		
		第三方风险数据		
	IP地址归属地	数据部黑名单		
		风控发名单		
		盗刷		
		出清高危区域		
		借款高危区域		
		手工录入		
用户ID	身份证号	羊毛党		
		老赖用户		
		贷款中介		
		第三方风险数据		
		数据部黑名单		
		盗刷		
	设备ID	风控发名单		
		欺诈用户		
		手工录入		
		羊毛党		
		老赖用户		
		贷款中介		

记录各标签标记时间、取消时间、标记次数
记录各条数据的录入时间、取消时间、录入次数



以数据安全风险为核心



以数据安全风险为核心

角色名称	应用编码	排序	上级角色	拥有资源	备注	操作
✎ 统一权限系统	irendai.com	1		统一权限系统, 申请列表, 应用日志, 日志列表, 日志详情, 审计	统一权限系统	  
✎ 审计	irendai.com	1	统一权限系统	用户管理, 用户信息的增, 用户列表, 用户批量授权, 用户类型, 用户管理员, 无添加权限		  
✎ 用户管理员-授权	irendai.com	1	统一权限系统	角色管理, 添加角色, 添加角色页, 编辑角色, 编辑角色页, 删除角色管理, 删除角色		  
✎ 角色管理员	irendai.com	1	统一权限系统	统一权限系统, 资源管理, 添加资源, 添加资源页, 编辑资源, 用户管理员		  
✎ 用户管理员-有添加权限	irendai.com	1	统一权限系统	删除分组, 批量删除, 获取分组信息, 获取分组网络列表, 权限申请角色		  
✎ 权限申请	irendai.com	1	统一权限系统	统一权限系统, 申请列表, 资源管理, 添加资源, 添加资源页, 应用管理员		  
✎ 应用管理员	irendai.com	1	统一权限系统	用户分组, 添加分组, 添加分组页, 编辑分组, 编辑分组页, 用户分组管理员		  
✎ 用户分组管理员	irendai.com	1	统一权限系统	资源管理, 添加资源, 添加资源页, 编辑资源, 编辑资源页, 删除资源, 资源管理员		  
✎ 资源管理员	irendai.com	1	统一权限系统		test	  
✎ emma_test	irendai.com	4	统一权限系统		test	  
✎ test	irendai.com	1	emma_test		test	  
✎ 保险系统	iyirendai.com	2			保险系统	  
✎ 保险运维操作员	iyirendai.com	1	保险系统	日常运维, 日常运维页, 执行日常运维, 首页	保险运维操作员	  
✎ 保险运营-订单查询	iyirendai.com	1	保险系统	订单, 订单列表, 订单列表页, 状态同步, 状态批量同步, 订单	保险运营-订单查询	  
✎ 保险运营-保单数据导出	iyirendai.com	1	保险系统	保单监控, 保单监控页面, 导出投保用户信息, 统计保单, 首页	保险运营-保单数据导出	  
✎ 保险系统管理员	iyirendai.com	1	保险系统	统一权限系统, 资源管理, 添加资源, 编辑资源, 删除资源, 资源, 资源管理员	保险系统管理员	  
✎ 基金交易管理系统	irendai.com	3			基金交易管理系统	  
✎ 研发	irendai.com	1	基金交易管理系统	基金管理, 基金产品管理, 基金属性, 查看基金属性, 生成下	研发	  
✎ 出借产品	irendai.com	1	基金交易管理系统	基金管理, 基金产品管理, 查看基金属性, 设置确认份额时	出借产品	  
✎ 出借运营高级	irendai.com	1	基金交易管理系统	基金管理, 主题基金管理, 生效失效标签, 调整权重标签, 取	出借运营高级	  
✎ 出借运营操作	irendai.com	1	基金交易管理系统	基金管理, 主题基金管理, 生效失效标签, 调整权重标签, 取	出借运营操作	  
✎ 出借运营工单	irendai.com	1	基金交易管理系统	基金管理, 主题基金管理, 生效失效标签, 调整权重标签, 取	出借运营工单	  
✎ 营销平台		4				  
✎ 申请记录		1	营销平台	运营平台系统, 首页, 用户运营管理, 申请记录		  
✎ 发起记录查看		1	营销平台	运营平台系统, 首页, 用户运营管理, 发起记录查询	发起记录查看	  
✎ 隔远发放申请人		1	营销平台	运营平台系统, 首页, 用户运营管理, 用户筛选	隔远发放申请人	
✎ 礼包记录查看		1	营销平台	运营平台系统, 首页, 自动化运营, 礼包发放记录	查看礼包发放记录	
✎ 消息记录查看		1	营销平台	运营平台系统, 首页, 用户运营管理, 消息记录查询		
✎ 消息任务管理员		1	营销平台	运营平台系统, 首页, 用户运营管理, 消息管理	消息的实时管理	
✎ 礼包管理员		1	营销平台	运营平台系统, 首页, 自动化运营, 礼包发放管理		

 资源管理

 用户管理

 用户分组

 角色管理

 应用管理

 权限申请

 应用日志

统一权限的管理、审计

以数据安全风险为核心

SQL查询

SELECT * FROM c_user_

执行 格式化 清理

ID	NAME	NAME	MAIL	R_PWD	TYPE	ID	NAME	FORCE	C	I	ER
2508	*****		*****	*****	0	1	*****0001	null	null		
2512	*****		*****	*****	0	1	*****0001	null	null		
2515	*****	*****an	*****	*****	1	1	*****10002	null	null		
2516	*****	*****仔	*****	*****	0	1	*****0001	null	null		
2518	*****	*****达人	*****	*****	0	1	*****010001	null	null		
2520	*****	*****哥	*****	*****	0	1	*****10001	null	null		
2530	*****	*****ne	*****	*****	0	1	*****0001	null	null		
2547	*****	*****整晚	*****	*****	0	1	*****001	null	null		

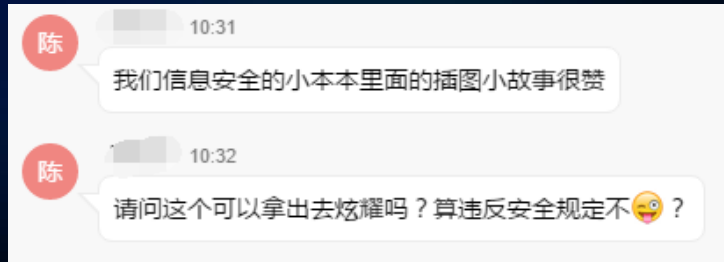
定期检索、维护需要做特殊处理的字段

Workflow: Remediate

Showing 34 incident(s) / 1 selected

ID	Incident Time	Source	Channel	Destination	Severity	Action	Maximum Matches	Transaction Size	File Name
2973752	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	Tencent QQ	Low	Blocked	74	253.84 KB	C:\Users\Administrator\...
2973753	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	Medium	Blocked	1	11.31 KB	C:\Users\Administrator\...
2973754	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973755	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	20	100 KB	C:\Users\Administrator\...
2973756	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	100	74.23 KB	C:\Users\Administrator\...
2973757	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973758	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973759	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973760	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973761	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973762	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973763	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973764	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973765	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973766	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973767	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973768	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973769	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973770	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973771	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973772	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973773	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973774	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973775	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973776	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973777	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973778	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973779	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973780	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973781	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973782	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973783	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973784	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973785	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973786	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973787	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973788	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973789	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973790	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973791	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973792	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973793	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973794	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973795	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973796	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973797	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973798	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973799	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...
2973800	2016-12-16 16:37:41	scan.vulnerability	Endpoint application	HTTP	High	Blocked	174	100 KB	C:\Users\Administrator\...

世界其实还是美好的



这样吧，先按创新产品的流量做方案，但是希望把buffer考虑进去，因为贷
感谢安全同事积极参与以及专业的建议，希望一起加强合作推进方案实施。

主题: Re: 回复: app找回密码模块DES加密改为AES加密
Hi all,
非常感谢安全部同事帮忙发现问题，针对提到的两点问题：

积分体系二期V2.2-8.9.docx (244 KB)
各位好，
非常感谢安全组的同事下午前来参加评审会，并给积分体系的安全性提供了宝贵建议。

今天刷s2-045的命令执行漏洞，硬是没找到宜人贷的，
贵公司的安全妥妥的

你们宜人贷好牛逼啊

【管理】
一个我都没找到

时间: 2015年5月20日 (周三) 19:50
大小: 95 KB
报告太专业了，有时间当面请教下，非常感谢安全的同学

选择信息安全工作，就代表了一份责任、一份使命、一份坚守，用自己的力量为企业保驾护航就是我们的价值所在



风雨同舟 坚持不懈